0. Dokumen

Judul: HRIS All-in-One — Software Requirements Specification (SRS) & Arsitektur v1.0
Client: Atar
Tanggal: 2025-08-19
Status: Draft untuk sign-off

---

1. Ringkasan Eksekutif

Sistem HRIS All-in-One untuk organisasi 50–5.000 karyawan, multi-entitas, multi-lokasi, multi-mata uang. Fokus: kepatuhan Indonesia (PPh21, BPJS, THR, lembur), UX cepat, keamanan kuat, integrasi mudah. Arsitektur modular-monolith (siap dipecah ke microservices) dengan multi-tenant RLS.

---

2. Ruang Lingkup & Tujuan

- **Ruang Lingkup**: Core HR, Struktur Organisasi, Rekrutmen/ATS, On/Offboarding, Attendance & Scheduling, Leave, Payroll (ID-first), Benefits & Claims, Performance, Learning, Expenses & Travel, Asset, Komunikasi, Analytics, Compliance & Security.
- **Out-of-scope (fase 1)**: Payroll negara selain Indonesia, LMS tingkat lanjut (SCORM authoring), T&A hardware provisioning, modul Talent Marketplace penuh.
- **Tujuan**: Mengurangi kesalahan payroll < 0,1%, mempercepat proses cuti/approval P95 < 5 menit, integrasi bank one-click, audit lengkap.

---

3. Definisi & Istilah

- **Tenant**: Unit pelanggan (per perusahaan/holding).
- **Entity**: Badan hukum di dalam tenant.
- **RLS**: Row-Level Security; pembatasan akses per tenant/entity.
- **Pay Group**: Kelompok gaji dengan jadwal dan aturan sama.
- **PPh21**: Pajak Penghasilan karyawan Indonesia.
- **BPJS**: Badan Penyelenggara Jaminan Sosial (Kesehatan & Ketenagakerjaan).
- **RTO/RPO**: Recovery Time / Point Objective.

---

4. Pemangku Kepentingan

- **Executive Sponsor**: COO/CHRO.
- **Admin HR**: mengelola master data & payroll.

- **Manager**: approval timesheet/leave/expense.
- **Employee**: self-service.
- **Finance**: jurnal payroll, rekonsiliasi.
- **IT/Ops**: SSO, perangkat, keamanan.

---

5. Peran Pengguna & Akses (RBAC)

Role	Akses Utama
Super Admin (Tenant)	Konfigurasi tenant, entity, kebijakan global, manajemen user & peran
HR Admin (Entity)	Master data, payroll, benefits, compliance, report
Manager	Approval (leave, timesheet, expense, overtime)
Employee	Self-service (profil, payslip, leave, attendance, expense)
Finance	Posting jurnal, rekonsiliasi, ekspor pajak/bank
IT Admin	SSO, perangkat attendance, integrasi

Prinsip: Least-privilege, policy-based (OPA/oso), semua aksi diaudit.

---

6. Persyaratan Fungsional (FR)

Semua ID requirement unik, format **FR-[Modul]-[Nomor]**.

6.1 Core HR & Organisasi

- **FR-CORE-001**: Sistem menyimpan master data karyawan (identitas, kontak, keluarga, NIK, NPWP, BPJS, rekening bank) dengan validasi format (regex) dan tanggal (ISO 8601).
- **FR-CORE-002**: Mendukung struktur: Company → Entity → Location → Department → Position → Grade → Cost Center.
- **FR-CORE-003**: Lifecycle karyawan (hire, transfer, promote, suspend, terminate) dengan effective-date & reason codes.
- **FR-CORE-004**: Document Vault dengan e-sign (PrivyID/DocuSign) dan enkripsi at-rest.
- **FR-CORE-005**: Audit trail immutable untuk create/update/delete pada semua tabel master.

6.2 Rekrutmen / ATS

- **FR-ATS-001**: Career site builder (tema, logo, SEO meta) dan form lamaran kustom.
- **FR-ATS-002**: Pipeline: Sourcing → Screening → Interview → Offer → Hired, dapat dikonfigurasi per job.
- **FR-ATS-003**: Jadwal interview sinkron dengan Google/Microsoft Calendar; undangan otomatis.

- **FR-ATS-004**: Offer letter generator (templating) + e-sign.
- **FR-ATS-005**: Dedup kandidat via email/phone + fuzzy match opsional.

6.3 Onboarding & Offboarding

- **FR-ONB-001**: Checklist lintas departemen dengan SLA dan reminder.
- **FR-ONB-002**: Provisioning akun (Google/Microsoft) via SCIM/OIDC claims.
- **FR-ONB-003**: Offboarding clearance (asset, akses sistem, payroll final) wajib sebelum termination effective.

6.4 Attendance & Scheduling

- **FR-ATT-001**: Clock in/out via mobile (GPS geofence), web, dan perangkat biometrik (ZKTeco/Hikvision) melalui gateway.
- **FR-ATT-002**: Offline mode mobile; event disimpan lokal dan disinkronkan ketika online, dengan idempotency key.
- **FR-ATT-003**: Shift & roster (fixed/rotating/split) + toleransi keterlambatan & grace period.
- **FR-ATT-004**: Timesheet project/task dengan approval berlapis.
- **FR-ATT-005**: Perhitungan lembur otomatis sesuai kebijakan & regulasi (konfigurabel).

6.5 Leave & Absence

- **FR-LV-001**: Cuti tahunan/sakit/melahirkan/custom dengan accrual, carry-over, prorata joiner/leaver.
- **FR-LV-002**: Kalender tim, blackout dates, dan syarat dokumen (MC) berdasarkan durasi.
- **FR-LV-003**: Notifikasi multi-channel (web/email/WA/Slack/Teams) untuk request & approval.

6.6 Payroll (Indonesia-first)

- **FR-PAY-001**: Skema PPh21: gross, gross-up, nett; PTKP & tarif pajak dinamis dari tabel konfigurasi.
- **FR-PAY-002**: BPJS Kesehatan & Ketenagakerjaan (JKK/JKM/JHT/JP) dengan batas upah, rate, dan pembulatan konfigurabel per periode.
- **FR-PAY-003**: THR, lembur, tunjangan shift, bonus, potongan pinjaman.
- **FR-PAY-004**: Simulasi payroll, multi-run, multi-pay-group; lock & re-open dengan log alasan.
- **FR-PAY-005**: E-payslip PDF; generator file bank (BCA, Mandiri, BNI, dll.) sesuai spesifikasi format.
- **FR-PAY-006**: Ekspor e-Filing PPh21 (CSV/XML sesuai template), rekap SIPP BPJS; jurnal otomatis ke sistem akuntansi.

6.7 Benefits & Claims

- **FR-BFT-001**: Enrollment BPJS/asuransi; plafon & co-pay per level/grade.
- **FR-BFT-002**: Reimbursement dengan upload bukti + OCR dasar; routing approval & GL mapping.

6.8 Performance & Goals

- **FR-PERF-001**: OKR/KPI dengan check-in berkala & 1:1 notes.
- **FR-PERF-002**: Siklus review (mid/final), 360° feedback, calibration.

6.9 Learning (LMS Ringan)

- **FR-LMS-001**: Katalog kursus (video/pdf/quiz), assignment otomatis.
- **FR-LMS-002**: Sertifikat dengan masa berlaku & reminder ekspiry.

6.10 Expenses & Travel

- **FR-EXP-001**: Klaim biaya (kategori, mata uang, kurs historis) + bukti.
- **FR-EXP-002**: Travel request → approval → itinerary; siap integrasi OTA.

6.11 Asset Management

- **FR-AST-001**: Lifecycle aset (assign/return/service), QR/Barcode, depresiasi straight-line opsional.

6.12 Komunikasi & Engagement

- **FR-COM-001**: Pengumuman bertarget; polling; kudos.

6.13 Analytics & Reporting

- **FR-BI-001**: Dashboard eksekutif (headcount, turnover, overtime, biaya SDM).
- **FR-BI-002**: Report builder (filter, group, pivot, export CSV/XLSX/PDF).
- **FR-BI-003**: Snapshot harian ke data warehouse (opsional) untuk time-travel.

---

7. Persyaratan Non-Fungsional (NFR)

- **NFR-AVAIL-001**: Ketersediaan prod $\geq$ 99,9%/tahun (tidak termasuk pemeliharaan terjadwal $\leq$ 4 jam/bulan).
- **NFR-PERF-001**: P95 API read $\leq$ 300 ms untuk query ringan; P95 page LCP $\leq$ 2,5 s pada koneksi 4G.
- **NFR-SCALE-001**: 100k karyawan/tenant, 5k user aktif konkuren.
- **NFR-SEC-001**: OWASP ASVS L2; enkripsi in-transit (TLS1.2+) & at-rest (AES-256/KMS).
- **NFR-OBSV-001**: Tracing (OpenTelemetry), logs terstruktur, metrics Prometheus.
- **NFR-BKP-001**: Backup harian + PITR; **RTO $\leq$ 1 jam, RPO $\leq$ 15 menit**.
- **NFR-A11Y-001**: WCAG 2.1 AA.
- **NFR-I18N-001**: i18n (Bahasa/English), zona waktu per entity, format lokal (ID).

---

8. Arsitektur & Stack

8.1 Arsitektur

- **Pattern**: Modular-monolith dengan boundaries DDD (Core, People, Time, Payroll, Finance, Talent, Comms, Integration).

- **Integrasi**: Event-driven (Kafka/RabbitMQ) + REST publik + webhook.
- **Multi-tenant**: Kolom `tenant_id` + `entity_id` pada seluruh tabel; PostgreSQL RLS aktif.

8.2 Stack (versi awal)

- **Frontend Web**: Next.js 14 (App Router), TypeScript, TanStack Query, Tailwind, shadcn/ui, React Hook Form + Zod, Recharts.
- **Mobile**: React Native (Expo) untuk self-service & attendance.
- **Backend**: NestJS 10 (TypeScript), REST + GraphQL internal opsional.
- **DB**: PostgreSQL 16 + Prisma ORM; RLS untuk isolasi tenant/entity.
- **Cache**: Redis 7 (session, rate-limit, queue ringan).
- **Bus**: Kafka (event penting: PayrollRunCompleted, AttendanceSynced, LeaveApproved). Alternatif ringan: RabbitMQ.
- **Search**: OpenSearch/Elasticsearch untuk global search & audit query.
- **Storage**: S3/MinIO untuk dokumen & PDF.
- **Auth**: Keycloak (OIDC/SAML, MFA); alternatif Auth0.
- **Secrets**: HashiCorp Vault / AWS Secrets Manager.
- **PDF/Export**: Playwright/Puppeteer.
- **ML-svc**: FastAPI (Python) untuk ATS ranking/anomali timesheet.

8.3 DevOps

- **Container**: Docker; **Kubernetes** (EKS/GKE/AKS) prod, Kind/minikube dev.
- **IaC**: Terraform + Helm.
- **CI/CD**: GitHub Actions (build, test, SCA, IaC validate, deploy blue/green).
- **Observability**: Grafana/Prometheus/Loki, Sentry, OpenTelemetry.
- **Testing**: Jest/Supertest (API), Playwright (E2E), k6 (load), Trivy (image scan).

---

9. Model Data (ringkas)

Entitas inti: Company, Entity, Location, Department, Position, Grade, Policy, Employee, Employment, Compensation, Document, Signature, AttendanceEvent, Shift, Schedule, Timesheet, Overtime, LeavePolicy, LeaveBalance, LeaveRequest, PayrollRun, PayGroup, Payslip, TaxComponent, BPJSComponent, ExpenseReport, ExpenseItem, Asset, AssetAssignment, Candidate, Application, Interview, Offer, Goal, KPI, Review, Feedback, Notification, Task, Checklist, AuditEvent.

Aturan umum: - Semua tabel memiliki `id (UUID v7)`, `tenant_id`, `entity_id` (nullable jika level tenant), `created_at`, `updated_at`, `deleted_at` (soft delete), `version` (optimistic locking). - Kunci business (unik per tenant): employee_no, npwp, nik, bank_account_no. - Tanggal & waktu UTC (ISO 8601), simpan timezone pada entity; render sesuai tz pengguna.

---

10. API Publik (kontrak)

Versi: v1; **Base**: `/api/v1`; **Format**: JSON; **Auth**: OAuth2 (Bearer), scopes per resource; **Idempotency**: header `Idempotency-Key` untuk POST/PUT sensitif; **Rate limit**: default 120 rpm per token.

10.1 Pola Umum

- **Pagination**: `page`, `page_size` (max 200), response berisi `total`, `items`.
- **Filter**: query param `q`, `filters[field]`, `sort=field:asc|desc`.
- **ETag**: GET mengembalikan `ETag`; PUT/PATCH gunakan `If-Match`.
- **Errors**: HTTP code + body `{ code, message, details, correlation_id }`.

10.2 Contoh Endpoint

Karyawan

- **POST** `/employees`

```
{
  "employee_no": "E-000123",
  "first_name": "Budi",
  "last_name": "Santoso",
  "email": "budi@contoh.co.id",
  "nik": "3276...",
  "npwp": "09.123.456.7-012.000",
  "hire_date": "2025-08-01",
  "entity_id": "UUID",
  "position_id": "UUID",
  "grade_id": "UUID"
}
```

201 Created → body berisi objek lengkap + `id` & `version`.

Attendance (Clock-in)

- **POST** `/attendance/events`

```
{
  "employee_id": "UUID",
  "type": "CLOCK_IN",
  "occurred_at": "2025-08-19T08:01:12Z",
  "source": "MOBILE",
  "geo": { "lat": -6.1754, "lng": 106.8272, "accuracy_m": 25 }
}
```

Balik **202 Accepted** + event `event_id`; proses async ke timesheet.

Payroll Run

- **POST** `/payroll/runs`

```
{
  "pay_group_id": "UUID",
  "period_start": "2025-08-01",
  "period_end": "2025-08-31",
  "payout_date": "2025-09-01",
  "options": { "simulate": true }
}
```

Balik **202 Accepted** dengan status URL `/payroll/runs/{id}`.

10.3 Webhook

- Contoh event: `payroll.run.completed`, `leave.request.approved`, `employee.created`.
- **Keamanan**: HMAC SHA-256 signature di header `X-Webhook-Signature`; retry eksponensial hingga 24 jam.

---

11. Integrasi (spesifikasi)

11.1 Identity & SSO

- **OIDC** (Authorization Code + PKCE), **SAML 2.0**; SCIM 2.0 untuk provisioning.
- Atribut wajib: `email`, `name`, `roles`, `entity_ids`.

11.2 Attendance Device Gateway

- Protokol: HTTPS push dari gateway → API `/devices/events` dengan batching (max 500 event/batch).
- Schema event: `{ device_id, employee_identifier, type, occurred_at, confidence }`.
- Idempotensi: hashing `device_id+timestamp+employee_identifier`.

11.3 Perbankan

- Generator file sesuai bank: BCA (TXT), Mandiri (CSV), BNI (CSV), dengan kolom: nomor rekening, nama, jumlah, referensi, deskripsi. Validasi checksum & panjang field.

11.4 E-Sign

- PrivyID/DocuSign: OAuth + template; callback status `signed/declined/expired`.

11.5 Akuntansi

- Jurnal: debit/kredit per akun (GL code) dengan referensi payslip; export CSV/JSON; adapter ke Jurnal/Accurate/Xero/NetSuite.

---

12. Keamanan (SEC)

- **SEC-AUTH-001**: SSO OIDC/SAML, MFA minimal TOTP; password policy (min 12 char, complexity, rotation opsional).
- **SEC-AUTHZ-001**: RBAC + policy engine (OPA/oso). Semua API cek scope + policy.
- **SEC-DATA-001**: Enkripsi at-rest (AES-256, KMS); field-level encryption untuk NIK/NPWP & nomor rekening.
- **SEC-NET-001**: TLS1.2+, HSTS, CSP ketat, IP allowlist untuk endpoint admin & webhook opsional.
- **SEC-APP-001**: Proteksi CSRF, rate limit, anti-automation; validasi input ketat (zod/class-validator).
- **SEC-AUDIT-001**: Audit event append-only, ditulis ke Kafka + S3 (WORM) dengan retensi 7 tahun.
- **SEC-PRIV-001**: Consent, data minimization, hak akses subjek data, data retention per jenis dokumen.

---

13. Observability & Operasional

- **Logs**: JSON terstruktur, `correlation_id` di setiap request.
- **Metrics**: p95 latency per endpoint, error rate, job queue depth, payroll throughput.
- **Tracing**: distributed trace (W3C Trace Context).
- **Runbooks**: incident triage, payroll stuck, backlog event, device offline.

---

14. Migrasi Data

- **Sumber**: Excel/CSV/HRIS lama.
- **Mapping**: template field standar per modul.
- **Validasi**: pre-flight (format, duplikasi, referential integrity), dry-run ke staging, sign-off user.
- **Anonymization**: opsional untuk sandbox.

---

15. Retensi Data & Arsip

- Dokumen kepegawaian: 7 tahun (default, dapat dikonfigurasi).
- Audit & payslip: 7 tahun.
- Hard-delete hanya melalui proses pemenuhan hak subjek data dengan jejak audit.

---

16. Backup & DR

- Backup harian penuh + WAL untuk PITR.
- Replikasi lintas region. **RTO ≤ 1 jam, RPO ≤ 15 menit**.
- Uji restore triwulanan; laporan hasil uji.

---

17. UI/UX Standar

- Desain responsive, dark mode opsional.
- Komponen konsisten (shadcn/ui), aksesibilitas (kontras, focus state, ARIA).
- Pola list/detail, wizard untuk proses payroll & onboarding.

---

18. Acceptance Criteria (per modul)

18.1 Payroll (ID)

- **AC-PAY-01**: 5.000 karyawan, satu pay group, run simulasi → hasil selesai ≤ 20 menit compute; selisih rekonsiliasi dengan template referensi = 0.
- **AC-PAY-02**: Generate file bank valid dan diterima sandbox bank (checksum & format lulus).
- **AC-PAY-03**: E-payslip terbit ≤ 2 menit setelah posting run; dapat diunduh di web & mobile.

18.2 Attendance

- **AC-ATT-01**: Event dari perangkat ke sistem terbaca P95 ≤ 10 detik.
- **AC-ATT-02**: Offline mobile: 100 event disinkron otomatis saat online tanpa duplikasi (uji idempotensi lulus).

18.3 Leave

- **AC-LV-01**: Accrual & carry-over mengikuti matriks kebijakan; akurasi ≥ 99% pada 100 skenario uji.

18.4 Security

- **AC-SEC-01**: SSO OIDC Google/Azure berfungsi; MFA wajib untuk admin.
- **AC-SEC-02**: OWASP ZAP/DAST tanpa temuan kritikal/high di prod sebelum go-live.

---

19. Pengujian

- **Unit** ≥ 70% statement coverage modul kritikal (Payroll, Attendance, Leave).

- **Contract test** untuk API publik (Pact).
- **E2E**: skenario hire→payroll→payslip; leave approval; attendance device→timesheet.
- **Load test**: k6 (100 req/s steady 15 menit, error < 0,1%).
- **Chaos** (opsional): simulasi kegagalan komponen cache/bus.

---

20. Rencana Rilis

1) **Foundational Release**: Core HR, Attendance, Leave, Payroll (ID).
2) **Wave 2**: ATS/Onboarding, Expenses, Asset.
3) **Wave 3**: Performance, Learning, Engagement.

---

21. Kebijakan Versi & Depresiasi

- API versioning via path `/v{n}`; dukungan min. 12 bulan per versi.
- Notifikasi perubahan mayor via email & changelog; header `Deprecation` & `Sunset` untuk endpoint lama.

---

22. Lampiran A — Skema Error Code

Code	HTTP	Deskripsi
`E_AUTH_001`	401	Token tidak valid/kedaluwarsa
`E_AUTHZ_001`	403	Scope/role tidak mencukupi
`E_VALID_001`	400	Validasi field gagal (detail per field)
`E_RATE_001`	429	Rate limit terlampaui
`E_CONFLICT_001`	409	Versi data berubah (optimistic lock)
`E_NOTFOUND_001`	404	Sumber daya tidak ditemukan
`E_INT_001`	500	Kesalahan internal (lihat correlation_id)

---

23. Lampiran B — Contoh Skema Database (subset)

```sql
-- Tenant & Entity
create table tenant (
  id uuid primary key,
  name text not null,
  created_at timestamptz not null default now()
);

create table entity (
  id uuid primary key,
  tenant_id uuid not null references tenant(id),
  name text not null,
  timezone text not null default 'Asia/Jakarta'
);

-- Employee (simplified)
create table employee (
  id uuid primary key,
  tenant_id uuid not null references tenant(id),
  entity_id uuid references entity(id),
  employee_no text not null,
  first_name text not null,
  last_name text,
  email text unique,
  nik text,
  npwp text,
  hire_date date not null,
  status text not null check (status in ('ACTIVE','INACTIVE','TERMINATED')),
  created_at timestamptz not null default now(),
  updated_at timestamptz not null default now(),
  version int not null default 1
);
create unique index uq_emp_no on employee(tenant_id, employee_no) where
deleted_at is null;
```

---

24. Lampiran C — Event Model (contoh payload)

```json
{
  "id": "evt_01HXYZ...",
```

```
  "type": "payroll.run.completed",
  "occurred_at": "2025-09-01T02:00:00Z",
  "tenant_id": "...",
  "entity_id": "...",
  "data": {
    "run_id": "...",
    "pay_group_id": "...",
    "employees": 4987,
    "gross": 12345678900,
    "net": 9876543200
  }
}
```

---

25. Lampiran D — Kebijakan Idempotensi

- Semua endpoint POST yang membuat resource menerima header `Idempotency-Key` (UUID).
- Server menyimpan hasil selama 24 jam; retry dengan key sama akan mengembalikan response identik.

---

26. Lampiran E — Kebijakan Pagination & Query

- `page` mulai dari 1; `page_size` default 50, maksimal 200.
- Sorting multi-kolom: `sort=field1:asc,field2:desc`.
- Filter nested pakai `filters[field.path]=operator:value` (operator: eq, ne, gt, gte, lt, lte, like, in).

---

27. Lampiran F — Kepatuhan Indonesia (Parameter Konfigurabel)

- **Tarif PPh21, PTKP, biaya jabatan, batas BPJS**: dikelola di tabel konfigurasi per periode; update tanpa redeploy.
- **Formula Lembur**: parameter koefisien dapat diubah per perjanjian kerja & peraturan perusahaan.
- **THR**: aturan prorata & eligibility berdasarkan masa kerja (hari/bulan) dapat dikonfigurasi.

---

28. Lampiran G — SLA & Dukungan

- **SLA**: 99,9% uptime; respon tiket prioritas 1 $\leq$ 30 menit; resolusi $\leq$ 8 jam.

• **Jadwal Maintenance**: diumumkan H-3, maksimal 4 jam/bulan.

---

29. Persetujuan

Dengan menandatangani, para pihak menyetujui ruang lingkup, requirement, dan kriteria penerimaan dokumen ini.

Client: ___ *Tanggal: _*
Vendor: ___ Tanggal: _